ARCHITECTURAL WHITEPAPER

Bonafide™

User-Sovereign Encrypted Data Vault Architecture

Open Specification for Quantized, Encrypted, Privacy-First Data Sovereignty

Sly Technologies Inc.

Version 1.1 — March 2026

Classification: Open Specification

Privacy by architecture, not by promise.

1. Executive Summary

Every major data breach of the last decade shares the same root cause: institutions store personal data in centralized databases protected by perimeter security. When the perimeter falls—and it always does—everything is exposed. Users bear 100% of the consequences with 0% of the control.

Bonafide is an open specification for a fundamentally different model. Instead of trusting institutions to protect your data behind their walls, Bonafide encrypts every piece of personal data independently, gives users the only master keys, and distributes encrypted fragments across the institutions that need them—with each institution able to see only what the user has authorized.

The core innovations:

- **Quantized encryption:** Personal data is decomposed into atomic units called quanta. Each quantum has its own encryption key, access policy, and tamper-proof audit trail. Compromise of one reveals nothing about any other.
- **State-of-the-art passwordless authentication:** No passwords. No recovery phrases. No shared secrets. Multi-factor authentication combines on-device identity verification within a hardware secure element with a user-chosen root secret stored in the device's enclave. The entire derivation is stateless—there is no stored "correct answer," no error on failure, no oracle for an attacker to probe.
- **Composable authentication gestures:** The root secret can be derived from any combination of physiological inputs (a specific fingerprint, a facial expression, a spoken word), behavioral inputs (keystroke rhythm, tap pattern, device movement), or traditional knowledge inputs. An attacker doesn't even know what type of input to attempt.
- **Three-path key architecture:** User keys are sovereign (only the user holds them). Institutional keys are sacrosanct (licensed exclusively for authorized operations, architecturally incapable of third-party access). Third-party keys are purpose-specific (generated on demand for sharing, verification, legal access, or emergency).
- **Vault-sovereign identity:** The user's only true identifier is derived from the vault itself—a per-institution hash that is cryptographically unlinkable across institutions. All human-readable names are aliases owned by the vault, portable across platforms, and revocable at any time. No platform owns your identity. No number suffixes. No forced uniqueness. Collision is resolved by context, not by mangling your name.
- **Lease-based institutional access:** Institutions hold time-bounded, auto-renewable leases—not permanent keys. Account closure automatically expires institutional access. Transfers require user consent. Silence defaults to rejection.
- **Privacy classifications:** Every institutional deployment carries a transparent, auditable privacy grade (S/A/B/C/U) based on hardware isolation, operational behavior, and audit results. Users see the grade before authorizing access.
- **Compliance by design:** Open and Regulated compliance profiles support global deployment with an explicit "no Surveillance Profile" commitment. No backdoors. No master keys. Lawful access through scoped, audited, purpose-specific mechanisms.
- **Open ecosystem:** Free specification, open-source reference implementations, certification program, three-phase governance evolution from corporate stewardship to community foundation.

Bonafide builds on cryptographic primitives already deployed in production within the ExaScale™ platform by Sly Technologies. The specification is open. Anyone can implement it.

2. The Problem

2.1 Broken Trust Model

A person's name, address, Social Security number, and financial history are duplicated across hundreds of institutional databases—each a potential breach target, each protected by the institution's own security decisions. When Equifax was breached, 147 million people lost control of data they never chose to share with Equifax in the first place.

2.2 Password Failure

Passwords are shared secrets: both the user and the service must know them. They are reused, phished, and stored in databases that get breached. Recovery phrases shift the burden to the user—lose your 24-word seed and your assets are gone. Neither model works for the general population.

2.3 No Revocation, No Accountability

When you close a bank account, your data doesn't leave with you. When your bank is acquired, your data transfers to a company you never chose—without your knowledge or consent. Institutional access has no expiration, no audit trail, and no user-controlled revocation. Accountability is a policy promise, not a verifiable fact.

2.4 Identity Fragmentation

Every institution independently assigns you a username, account number, or customer ID. Your identity is fragmented across dozens of incompatible namespaces—@mark823414234 here, customer #9847261 there. You are a tenant in every platform's namespace. No institution's identifier is portable to another. Close an account and your identity at that institution vanishes. Build an audience on one platform and you cannot carry it to another.

3. How Bonafide Works

3.1 The Quantum — Atomic Data Unit

A quantum is the fundamental unit of the Bonafide vault. It is a self-contained, independently encrypted package: a single record, document, image, or assertion. Each quantum is encrypted with its own AES-256-GCM key, carries its own access policy, and has its own Merkle tree entry for integrity verification. Authorizing access to one quantum reveals nothing about any other.

3.2 The Vault — Distributed Hierarchy

A user's vault is a tree of branches distributed across institutions. Chase Bank hosts the Chase branch. A hospital hosts the health branch. Neither can see the other's branch. The user's device holds the root key that unifies the tree. Branches contain channels (data streams within an institutional relationship), and channels contain quanta.

3.3 Composable Root Derivation

The cryptographic root of the vault is computed from three inputs: on-device identity verification (processed within the hardware secure element, never transmitted), a user-chosen root secret (stored as a hash in the device enclave, auto-appended transparently), and an optional manual passphrase (selects alternate personas when present).

The derivation is stateless: there is no stored correct answer. Every input combination produces a valid-looking 256-bit key. The system never indicates whether the result was correct. An attacker searching with wrong inputs gets a key that decrypts nothing, and they cannot distinguish failure from success. This is unique to Bonafide—every other authentication system provides an oracle.

3.4 Ghost Quanta

Most institutional interactions do not require raw data. Ghost quanta provide cryptographic proofs about data without exposing the data itself: zero-knowledge proofs, range proofs, set membership proofs, redacted summaries, and hashed confirmations. Institutions receive the answers they need without possessing the data.

3.5 Extensible Security Levels

The reference profile defines 10 security levels—from Level 0 (public identifiers) through Level 9 (sovereign root material). Each level determines key derivation depth, minimum device enclave tier, and minimum institutional privacy classification. A retailer accesses Levels 0–2. A bank reaches 0–4. A hospital reaches 0–5. Nobody except the user touches Level 8–9.

4. Vault-Sovereign Identity

In conventional systems, the platform owns your identity. You are @mark823414234 because the good names were taken. You build followers under a handle that the platform can suspend, reassign, or orphan. Your identity dies with your account.

Bonafide inverts this. Your only true identifier is a cryptographic hash derived from your vault—unique per institution, unlinkable across institutions, and owned by you. Everything else—@alice, @dr-chen, “Alice Chen”—is an alias. Aliases are vault-owned, portable, and revocable.

4.1 Address Grammar

Every identity in the Bonafide ecosystem follows a formal address grammar: @name:namespace+pin[qualifiers].id. The .id suffix is a protocol namespace marker (not a DNS domain) that resolves through the Bonafide validator network. Names are simple and human. All complexity—attestations, credentials, geographic scope, delivery preferences—lives in qualifier brackets.

4.2 No Global Uniqueness Required

Names are locally unique within a scope, not globally. Two users named @alice coexist peacefully. Disambiguation happens at the moment of addressing—a contextual picker surfaces the right Alice based on your relationship, their reputation, and their qualifiers. The user selects once; the vault remembers. No number suffixes. No ugly postfixes.

4.3 Alias Portability

A creator who builds audience as @mayachen on one platform carries that alias—and the vault-attested reputation history—to any other Bonafide-compliant platform. The alias lives in the vault, not in any platform’s database. No platform can hold a creator hostage by orphaning their identity.

4.4 Three Identity Classes

Class	Sigil	Example	Properties
Human	@	@alice.id	Vault rooted in device secure element. Per-institution branch hashes. Unlinkable across institutions.
Institutional	@	@chase-bank.id	Same protocol as human. Organizational credentials instead of personal identity verification.
Agent	@	@assistant:alice.id[bot]	Anchored to a principal vault. Principal is accountable. Trust ceiling bounded by principal’s score.

4.5 Topics and Communities

Topics and communities use the # sigil with the same grammar. Three participation tiers: open (anyone can participate), attested (zero-knowledge proof of credential required), and sealed

(invitation-only with shared group key). A medical professionals community can require [attest:*.md] without any moderator or validator seeing the underlying credential.

5. Three-Path Key Architecture

Bonafide defines three distinct key paths. Each has a strictly bounded purpose. No key path can serve another's function.

5.1 User Key — Sovereign

Derived from the vault root. The user can access their data from any enrolled device without institutional cooperation. Never shared with any institution or third party.

5.2 Institutional Key — Sacrosanct

Lease-based: time-bounded, auto-renewable credentials that authorize access for a finite term (default: 30 days). Cannot serve third-party access—not for law enforcement, not for regulators, not for partners. This protects institutions from coercion. When a lease expires, the institutional identity at that institution becomes unresolvable—identity and access are cryptographically linked.

5.3 Third-Party Key — Purpose-Specific

Generated on demand for sharing, verification, legal access, or emergency. Scoped, time-bounded, recipient-bound, derived from the authorization that created it. Multiple third-party keys coexist independently.

6. Third-Party Access

Four categories, all using purpose-specific keys:

- **User sharing:** Share links with forensic watermarking, view-once/time-bounded/revocable modes. Share links are the onramp for new users.
- **Institutional verification:** Ghost quanta by default. Merchant receives a cryptographic proof, not raw data. Two institutions' keys never meet.
- **Legal and audit:** Validated legal instrument → purpose-specific key derived from instrument hash. Snapshot or monitoring modes. Institution not involved.
- **Emergency:** Pre-configured profile, short-lived keys (24 hours), medical/identity data only.

7. Privacy Classifications

Every institutional deployment carries a transparent, auditable privacy grade. Users see the grade before authorizing access.

Classification	Key Isolation	Plaintext Exposure	Revocation	Hardware
S — Sovereign	Bonafide HSM	Never leaves enclave	Absolute	Bonafide HSM / Dedicated SE
A — Attested	Hardware TEE	Within TEE only	Effective	TEE-capable CPU or DPU
B — Bounded	Software process	In API responses	Operational	Optional HSM/TPM
C — Compliant	Runtime only	In application stack	Partial	None required
U — Unclassified	Not audited	Unknown	Unknown	Not verified

Classifications are not self-reported. They are determined by automated hardware attestation and periodic audits. The privacy score (0–100) combines the structural baseline with behavioral metrics: ghost quanta usage, revocation compliance, override frequency, and breach history.

8. Personas and Duress Protection

8.1 Multiple Identities

The optional passphrase component enables multiple cryptographically independent personas from the same identity verification. Each persona has its own vault tree, its own institutions, its own aliases, its own routing. No institution seeing one persona can correlate it to another. The existence of additional personas is undetectable.

8.2 Duress Protection

Under coercion, the user authenticates without a passphrase. The default persona opens—configured as a decoy with plausible but non-sensitive data. Silent alerts optionally notify trusted contacts. The decoy has valid encryption, valid Merkle proofs, and realistic content—indistinguishable from a real vault.

8.3 Content Neutrality

The vault encrypts, authorizes, and audits. It does not inspect, filter, or classify content. No backdoors. No content scanning. If a jurisdiction requires content scanning, Bonafide cannot be deployed there.

9. Blind Validation Network

Validators verify high-value lifecycle events—lease grants, renewals, revocations, transfers, policy changes, and third-party access authorizations. They also resolve identity addresses through majority consensus and verify credential attestation qualifiers using zero-knowledge proofs. Validators see cryptographic proofs, not data.

The network uses Byzantine fault tolerant consensus with organizational, geographic, and network diversity constraints. Trust scores (0–1000) track validator behavior with automatic suspension below threshold. Identity trust scores extend the same model to vault identities—computed functions based on alias velocity, attestations, community signals, and vault age.

10. Network Security

- **Transport:** Mutual TLS everywhere. TLS 1.3 with AEAD-only ciphers. Hardware-accelerated TLS on Bonafide HSM and DPU deployments.
- **Client authentication:** Device attestation required for every connection. Guest enclave for unrecognized devices.
- **DoS defense:** Five-tier capacity architecture. Proof-of-work for unauthenticated requests. Anycast distribution.
- **Traffic analysis resistance:** Constant-rate padding, uniform sizing, timing jitter, optional ORAM.
- **Anti-duplication:** Ghost quanta, forensic watermarking, canary quanta, privacy scoring, API abstraction.
- **Incident response:** Trust scores as automated immune system. Certificate revocation within 60 seconds.

11. Enclave Architecture and Hardware

11.1 Device-Side Enclaves

Five enclave tiers from Tier S (Bonafide HSM, Level 9 access) to Tier 4 (software-only, Level 3). Flagship phones reach Tier 1. Every modern smartphone and laptop can participate; the tier determines the maximum security level accessible.

11.2 Server-Side Hardware

- **Bonafide HSM (Classification S):** Keys in PUF, AES in fabric, ZK proofs in fabric. Plaintext never touches host memory.
- **Cloud TEE (Classification A):** AWS Nitro Enclaves, Azure Confidential VMs. Lowest barrier to Classification A.
- **HSM + Accelerator (Classification B):** Key storage in hardware, bulk crypto in accelerator.
- **Software only (Classification C):** Starting point for incremental adoption.

12. Compliance and Global Deployment

12.1 Compliance Profiles

The Open Profile is the canonical specification: full content neutrality, no backdoors. The Regulated Profile adds configurable compliance controls for jurisdictions with lawful access requirements. The specification explicitly does not define and will never define a Surveillance Profile.

12.2 Global Market Tiers

Tier	Profile	Jurisdictions
Tier 1 — Open	Open Profile	US, Canada, Switzerland, Japan, South Korea, Taiwan, Israel, Brazil, most of Latin America
Tier 2 — Regulated	Regulated Profile	EU (GDPR + eIDAS), UK, Australia, India, Singapore, France, Germany
Tier 3 — Institutional Only	Enterprise deployment	Russia, Turkey, UAE, Gulf States, Thailand
Tier 4 — Cannot Deploy	Specification prohibits	China, Iran, North Korea, Myanmar, Vietnam

Bonafide meets or exceeds NIST 800-63 AAL2/AAL3, PSD2 SCA, FIDO2/WebAuthn, GDPR, HIPAA, PCI-DSS v4.0, CCPA, and eIDAS 2.0.

13. What Existing Systems Cannot Do

Capability	Passwords / SSO	Crypto Wallets	Federated ID	Bonafide
No shared secrets	Password is shared	Seed phrase risk	OAuth tokens	On-device verification + root secret
No oracle on failure	Login succeeds/fails	Tx succeeds/fails	Token valid/invalid	Silence — no signal
Portable identity	Platform-owned	Wallet address	Provider-dependent	Vault-owned aliases, portable across platforms
No number suffixes	mark823414234	0x7f3a...9c2d	N/A	Clean names, runtime disambiguation
Per-institution isolation	Central DB	N/A	Partial	Full — unlinkable branch hashes
Granular revocation	All or nothing	All or nothing	Token revocation	Per-quantum, per-channel, per-branch
Lease-based access	Permanent	Permanent	Token TTL	Auto-renewable, auto-expiring leases
Privacy classifications	N/A	N/A	N/A	Audited S/A/B/C/U grades
Agent accountability	N/A	N/A	N/A	Principal-anchored [bot] with model attestation
Content neutrality	Platform-dependent	Protocol-level	Platform-dependent	Specification requirement

14. Open Ecosystem

14.1 What Anyone Can Build

The specification is free. Reference implementations are open source. Third parties build vault providers, validator nodes, relay operators, hardware devices, database integrations, consumer apps, verification services, and privacy tools. Certification ensures interoperability.

14.2 Institutional Onramp

Institutions adopt incrementally: database encryption packages (Classification C), runtime API (Classification B), TEE hardware (Classification A), Bonafide HSM enclaves (Classification S). Each phase delivers compliance benefit. No flag-day migration required.

14.3 User Onramp

Users discover Bonafide through share links, institutional adoption, or direct download. The guest enclave flow bootstraps a new vault in minutes. Aliases are portable—users carry their identity and reputation to any Bonafide-compliant platform.

14.4 Governance Evolution

Phase 1 (current): Sly Technologies stewards the specification. Phase 2: an independent Bonafide Foundation takes ownership. Phase 3: fully community-governed. Master keys, bulk access, and content scanning are never added.

14.5 Revenue Model

Bonafide Cloud subscriptions, ExaScale integration, Bonafide Personal premium features, certification fees. The specification is always free. User data is never monetized.

15. Specification Reference

The Bonafide V1.0 specification is organized into 15 parts:

Part	Title	Scope
1	Foundation & Core Architecture	Vault hierarchy, quantum model, design principles, participation models, security levels, ledger
2	Cryptographic Foundation	Composable root derivation, gesture system, identity verification, key hierarchy, encryption, Merkle integrity
3	Security Levels & Authentication	Level system, MFA compliance mapping, auth flows, elevation, session management, duress
4	PII Protection & Privacy	Proxy identity, privacy scoring, canary detection, watermarking, data minimization, erasure, portability
5	Blind Validation Network	ZK proof system, trust scoring, validator selection, BFT consensus, Sybil resistance
6	Infrastructure & Portfolio	Database packages, cloud coordination, ExaScale integration, namespace, products, revenue
7	Personas & Identity	Multi-persona architecture, duress protection, focus profiles, content neutrality, persona lifecycle
8	Open Ecosystem & Governance	Ecosystem philosophy, federated relay, certification program, governance evolution, adoption strategy
9	Network Security & Abuse Prevention	Threat model, transport security, DoS defense, validator protection, traffic analysis resistance
10	Enclave Architecture & Device Classes	Enclave tiers, device profiles, peripherals, server hardware, cross-device sync
11	Privacy Classifications	S/A/B/C/U definitions, audit methodology, upgrade path, score integration
12	Institutional Runtime & Data Governance	Runtime architecture, three-path keys, third-party access, revocation, anti-duplication, HAL
13	Compliance Profiles & Global Deployment	Open/Regulated profiles, market tiers, regulatory mapping, data residency
14	Institutional Branches, Leases & Policy	Lease-based access, machine-executable branch policy, transfer protocol, policy immutability
15	Identity, Addressing & Alias Resolution	Address grammar, .id namespace, qualifier system, vault-owned aliases, display resolution, agent identities, collision disambiguation, identity trust scores, routing

16. Institutional Branch Lifecycle

Part 14 defines the complete lifecycle of institutional data relationships:

16.1 Lease-Based Institutional Access

Institutions hold leases, not permanent keys. A lease grants decryption access for a finite term (default: 30 days), renews automatically unless revoked, and is always user-revocable. When a lease expires, the institutional identity at that institution simultaneously becomes unresolvable—identity and access are cryptographically linked.

16.2 Machine-Executable Branch Policy

Every institutional branch publishes a cryptographically signed policy document. The policy declares what data the institution stores, at what security levels, for how long, and what happens under lifecycle events. The policy is machine-executable—enforced in real time by the runtime or by the Bonafide HSM in FPGA fabric.

16.3 Transfer Protocol

When an institution is acquired, the protocol does not allow automatic inheritance. The user receives a protocol-level notification with options to accept or reject. If the user does not respond within the notice period, the default is reject. Silence is not consent.

16.4 Policy Immutability

An institution cannot unilaterally change the policy the user agreed to. Term updates require explicit user acceptance through the protocol—not email, not terms-of-service clickthrough.

17. Vision

Bonafide exists because the current model is fundamentally broken. Institutions collect more data than they need, protect it with perimeter security that fails, and leave users with no control and no recourse. Passwords need to stop existing. Centralized identity databases are targets that cannot be defended indefinitely. Your username should not be @mark823414234.

The answer is making the data itself sovereign—encrypted at the atomic level, keyed to the individual, distributed so that no breach exposes more than opaque ciphertext. The institution's role shifts from guardian of data to host of encrypted fragments whose content it cannot see without user authorization.

Your identity is yours. Your aliases are portable. Your reputation follows you. When you close an account, the institution's access expires automatically—because the cryptographic lease you granted has ended and the identity you presented has become unresolvable. When your bank is acquired, your data doesn't silently transfer—you decide.

No passwords. No centralized honeypots. No backdoors. No master keys. No number suffixes. No platform-owned identities. No more hoping institutions protect what they were never supposed to see in the first place.

Bonafide™ — Privacy by architecture, not by promise.

An open specification by Sly Technologies Inc. | bonafide.id | bonafideid.org
V1.1 — March 2026